Information Security Policy

Example Manufacturing GmbH. Document IS-01, version 3.2, owner: Chief Information Security Officer (CISO), effective 1 March 2026.

1. Purpose and Scope

This policy sets the minimum security requirements for protecting company information and IT systems. It applies to all employees, contractors and third parties with access to company information systems at all sites in Germany and the Czech Republic.

The information security management system is aligned with ISO/IEC 27001:2022. Topic-specific rules are defined in this policy and in the related procedures, such as the Incident Response Procedure (IS-07).

2. Roles and Responsibilities

The CISO owns this policy and reviews it at least once a year. IT Operations implements the technical controls described here. Managers make sure that everyone in their team completes the annual security awareness training by 31 March of each year.

Every employee must protect the information entrusted to them and report security incidents and weaknesses without delay.

3. Access Control

Access is granted on the principle of least privilege. Access requests are submitted through the IT service portal and must be approved by the employee's manager and, for business applications, by the application owner.

Access rights are reviewed every 6 months for standard systems. Privileged accounts and access to the SAP ERP system are reviewed every 3 months. Accounts of leavers are disabled on their last working day.

Shared user accounts are not allowed. The only exception are emergency break-glass accounts, whose credentials are stored in the company password vault and whose use is logged and reviewed.

4. Passwords and Authentication

Passwords must have at least 14 characters. Passwords are not changed on a fixed schedule; a change is required when there is any sign that a password may be compromised. Company passwords must not be reused for private accounts. Employees should use the company password manager.

Multi-factor authentication (MFA) is mandatory for remote access through VPN, for email and collaboration tools used from outside the company network, for all administrator accounts and for all cloud services that hold company data.

5. Endpoint Security

All laptops use full-disk encryption. Screens lock automatically after 10 minutes of inactivity. The endpoint detection and response (EDR) agent must not be disabled or removed.

USB mass storage devices are blocked by default. An exception can be approved by the CISO for a specific business need for a maximum of 90 days. Personal devices may access company email only through the managed mobile app.

6. Patch and Vulnerability Management

Security updates are installed within the following deadlines after release: critical vulnerabilities (CVSS 9.0 and higher) within 14 days, high vulnerabilities (CVSS 7.0 to 8.9) within 30 days, medium vulnerabilities within 90 days and low vulnerabilities with the next regular release.

If a vulnerability is known to be actively exploited, for example because it is listed in the CISA Known Exploited Vulnerabilities catalog, the update must be installed within 72 hours.

Servers are patched in the monthly maintenance window on the second Saturday of each month. Systems that cannot be patched, such as production machines in the OT network, require documented compensating controls and an exception approved by the CISO. Such exceptions are reviewed every 6 months.

7. Network Security

The production (OT) network is separated from the office network. Remote access by machine vendors to the OT network is only allowed through the central jump host, and these sessions are recorded. The guest Wi-Fi is isolated from all internal networks.

8. Backup and Recovery

Critical systems are backed up daily and backups are kept for 30 days. At least one backup copy is stored offline or in immutable storage. Restoring from backup is tested every quarter.

9. Exceptions and Enforcement

Exceptions to this policy are requested with the exception request form and approved by the CISO for a maximum of 12 months. Violations of this policy may lead to disciplinary action.